

Cyber Security Operations Platform

SOC Operating Model, Roles, SLAs and Playbooks

Document purpose

This document is part of a build-and-operate pack for a modular Cyber Security Operations Platform capable of SOC-as-a-Service, MDR, Managed XDR, sovereign SOC, enterprise private SOC, and MSSP white-label deployments.

1. Operating model summary

The SOC service combines platform automation with human-led security operations. The platform must support a repeatable operating model for triage, investigation, containment, communication, reporting, governance and continuous improvement.

2. SOC roles and responsibilities

Role	Responsibilities	Key outputs
SOC Director	Owns service performance, client trust, staffing, governance and escalation.	Monthly service board, KPI pack, major incident oversight.
SOC Manager / Shift Lead	Runs daily operations, shift handover, quality checks, escalation coordination.	Shift logs, QA reviews, escalation decisions.
Tier 1 Analyst	Initial triage, alert validation, enrichment, false-positive handling, case creation.	Triage notes, initial severity, customer notification draft.
Tier 2 Analyst	Deep investigation, correlation, containment recommendation, playbook execution.	Incident timeline, evidence pack, containment plan.
Tier 3 / Threat Hunter	Advanced threat hunting, malware/forensic support, detection hypothesis and root-cause analysis.	Hunt reports, detection improvements, IR findings.
Detection Engineer	Creates and tunes rules, maps MITRE coverage, manages false positives and regression testing.	Detection catalogue, rule releases, coverage heatmap.
Incident Response Lead	Owns major incidents, coordinates containment, eradication, recovery and communications.	IR plan, executive updates, post-incident review.
Customer Success Manager	Onboarding, service reviews, renewals, expectations and escalations.	Service review pack, renewal plan, customer action log.
Platform/DevSecOps Engineer	Keeps platform secure, available, observable and patched.	Release notes, uptime reports, remediation tickets.

3. 24/7 coverage model

Start with a pragmatic model that can scale: business-hours local analyst team plus out-of-hours monitoring/on-call during pilot, then move to full rota as tenant volume and revenue support it. Critical tiers require explicit 24/7 SLA coverage.

Maturity stage	Coverage model	Suitable phase
Pilot	Business-hours triage plus on-call major incident escalation	First 5-10 tenants.
Early SOCaaS	16x5 or 24x7 light monitoring using rota + on-call	10-30 tenants.
Production SOC	24x7 shift model with Tier 1 coverage and Tier 2 on-call	30+ tenants and regulated clients.
Advanced MDR	24x7 Tier 1/Tier 2 with Tier 3/IR retainer escalation	Critical infrastructure and enterprise customers.

4. Severity model

Severity	Definition	Example	Target handling
P1 Critical	Confirmed or highly likely active compromise impacting critical systems or privileged identity.	Ransomware activity, active data exfiltration, domain admin compromise.	Immediate escalation; senior analyst/IR lead; customer contacted under contract SLA.
P2 High	Credible threat requiring urgent investigation and possible containment.	Malware on critical endpoint, suspicious impossible travel with privileged account.	Fast triage and escalation; containment recommendation.
P3 Medium	Suspicious activity requiring investigation but no immediate evidence of active compromise.	Repeated failed logins, suspicious email clicks, unusual process execution.	Queue triage, enrich, tune, customer action if needed.
P4 Low	Informational or low-risk event requiring monitoring or tuning.	Known scanner activity, policy violation, non-critical anomaly.	Batch review and monthly reporting.

5. Standard incident lifecycle

Stage	Description
1. Receipt	Alert/log received through integration, API, syslog or manual entry.
2. Triage	Analyst validates alert, checks context, determines false positive vs suspected incident.
3. Case creation	Relevant alerts are converted into a case with severity, impacted entities and SLA.
4. Investigation	Evidence collected, timeline built, related events correlated and AI summary reviewed.
5. Containment recommendation	Analyst proposes action; customer approval requested if required by authority-to-act.
6. Response execution	SOAR/manual actions executed, logged and validated.
7. Eradication/recovery support	Root cause and remediation guidance tracked to closure.
8. Closure	Customer-approved closure with incident report, lessons learned and detection tuning actions.

6. Authority-to-act model

Mode	Description	Examples
Observe only	SOC investigates and recommends but does not make changes.	Most pilots, low-trust onboarding stage.
Approval required	SOC proposes action; customer approves via portal or named contact.	Disable account, isolate endpoint, block IP/domain.
Pre-authorised actions	SOC may execute agreed low-risk actions within defined thresholds.	Quarantine malicious email, disable confirmed compromised test account, create ticket.
Emergency authority	Rare critical tier option with contractual thresholds and immediate notification.	Contain ransomware spread after pre-agreed conditions are met.

7. Core playbooks

Playbook	Required workflow
Phishing / BEC	Email indicators, clicked users, mailbox rules, forwarding, OAuth grants, similar messages, user reset guidance.
Compromised identity	Risky sign-in, MFA fatigue, impossible travel, token revocation, password reset, privilege review.
Malware / endpoint compromise	Device isolation decision, process tree, hash/domain enrichment, EDR action, reimage guidance.
Ransomware suspected	Containment tree, affected assets, lateral movement indicators, backup protection, executive escalation.
Cloud account compromise	API activity, IAM changes, key rotation, suspicious resources, cloud guardrail validation.
Firewall/network anomaly	Source/destination pattern, threat intel, blocklist action, perimeter configuration review.
Data exfiltration suspected	Outbound volume, destination, sensitive assets, legal/privacy escalation, evidence preservation.
Vulnerability exploitation	Exposure validation, exploit intel, patch/workaround, compensating controls.

8. Customer onboarding workflow

Step	Activity	Output
Contract and scope	Confirm service tier, assets, log sources, retention, SLAs and authority-to-act.	Signed service schedule and onboarding checklist.
Technical readiness	Validate network access, API credentials, connector permissions and collector setup.	Integration plan and credential register.
Baseline	Collect first telemetry, map assets/users, identify noisy rules and critical systems.	Baseline profile and tuning backlog.

Go-live readiness	Test alert path, contact tree, P1 exercise, reporting templates and escalation.	Go-live approval.
Hypercare	Daily checks and rapid tuning for first 2-4 weeks.	False positive reduction and stable service.

9. KPIs and governance

KPI	Target direction	Purpose
Mean Time to Triage	Reduce; P1 target <15 minutes for premium tiers	Measures initial SOC responsiveness.
Mean Time to Escalate	Reduce and meet SLA	Measures customer communication and severity handling.
False-positive rate	Reduce within first 90 days per tenant	Measures detection quality and tuning.
Connector health	>95% healthy for active integrations	Measures monitoring completeness.
Case closure quality	QA score >90%	Measures analyst evidence, notes and report quality.
SLA compliance	>95%	Commercial and service governance.
Detection coverage	Increase across MITRE tactics relevant to tenant risk	Measures security value.

Reference standards and sources

NIST Cybersecurity Framework 2.0: <https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final>

NIST SP 800-61 Revision 3 Incident Response Recommendations: <https://csrc.nist.gov/pubs/sp/800/61/r3/final>

MITRE ATT&CK Enterprise Matrix: <https://attack.mitre.org/matrices/enterprise/>

OCSF Open Cybersecurity Schema Framework: <https://ocsf.io/>

Sigma Detection Format: <https://sigmahq.io/docs/basics/rules.html>

OASIS STIX/TAXII Cyber Threat Intelligence Standards: https://www.oasis-open.org/committees/tc_home.php?wg_abbrev=cti

CIS Critical Security Controls v8.1: <https://www.cisecurity.org/controls/v8-1>

FIRST Traffic Light Protocol 2.0: <https://www.first.org/tlp/>